

## Efficient Privacy-Preserving User Authentication Scheme with Forward Secrecy for Industry 4.0

[Wang Chenyu](#), [Wang Ding](#), [Xu Guoai](#) and [He Debiao](#)

Citation: [SCIENCE CHINA Information Sciences](#); doi: 10.1007/s11432-020-2975-6

View online: <http://engine.scichina.com/doi/10.1007/s11432-020-2975-6>

Published by the [Science China Press](#)

---

### Articles you may be interested in

[EFFECT: an efficient flexible privacy-preserving data aggregation scheme with authentication in smart grid](#)

SCIENCE CHINA Information Sciences **62**, 032103 (2019);

[A privacy-preserving video subscription scheme with the limitation of expire date](#)

SCIENCE CHINA Information Sciences **60**, 098101 (2017);

[PPLS: a privacy-preserving location-sharing scheme in mobile online social networks](#)

SCIENCE CHINA Information Sciences **63**, 132105 (2020);

[A privacy-preserving data collection model for digital community](#)

SCIENCE CHINA Information Sciences **58**, 032101 (2015);

[Scalable privacy-preserving big data aggregation mechanism](#)

数字通信和网络 **2**, 122 (2016);

---



### Efficient Privacy-Preserving User Authentication Scheme with Forward Secrecy for Industry 4.0

|                               |                                                                                                                                                                                                                                                                                   |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Journal:                      | SCIENCE CHINA Information Sciences                                                                                                                                                                                                                                                |
| Manuscript ID                 | SCIS-2020-0167.R2                                                                                                                                                                                                                                                                 |
| Manuscript Type:              | Research Paper                                                                                                                                                                                                                                                                    |
| Date Submitted by the Author: | 24-Jun-2020                                                                                                                                                                                                                                                                       |
| Complete List of Authors:     | Wang, Chenyu; Beijing University of Posts and Telecommunications, School of Cyber Security<br>Wang, Ding; Nankai University, College of Cyber Science<br>Xu, Guoai; Beijing University of Posts and Telecommunications, School of Cyber Security<br>He, Debiao; Wuhan University, |
| Keywords:                     | Industry 4.0, Wireless sensor networks, Password authentication, Forward Secrecy, Offline dictionary attack                                                                                                                                                                       |
| Speciality:                   | Sensor net work communications < Information & Communication Engineering                                                                                                                                                                                                          |
|                               |                                                                                                                                                                                                                                                                                   |

SCHOLARONE™  
Manuscripts

• RESEARCH PAPER •

Efficient Privacy-Preserving User Authentication  
Scheme with Forward Secrecy for Industry 4.0

Chenyu Wang<sup>1,2</sup>, Ding Wang<sup>3,4,2\*</sup>, Guoai Xu<sup>1</sup> & Debiao He<sup>5</sup>

<sup>1</sup>School of Cyber Security, Beijing University of Posts and Telecommunications, Beijing 100876, China;

<sup>2</sup>State Key Laboratory of Cryptology, P.O. Box 5159, Beijing 100878, China;

<sup>3</sup>College of Cyber Science, Nankai University, Tianjin 300350, China;

<sup>4</sup>Tianjin Key Laboratory of Network and Data Security Technology, Nankai University, Tianjin 300350, China;

<sup>5</sup>School of Cyber Science and Engineering, Wuhan University, Wuhan 430072, China

**Abstract** Industry 4.0, which combines information technology, network and industrial production, is expected to have a tremendous impact on our daily lives. In such a complex and security-critical system with resource-constrained sensor nodes, the design of a secure user authentication scheme for preventing real-time data from unauthorized access is full of challenges, and the main crux lies in how to realize the important property of forward secrecy. Existing schemes either fail to achieve forward secrecy or achieve forward secrecy with high computation cost on sensor nodes. Besides, they often fail to conform to the development trend of industry 4.0 systems where a cloud center is necessary to help intelligent decision-making and alleviate computation and storage pressure. Therefore, in this paper, we propose an efficient privacy-preserving user authentication scheme with forward secrecy for industry 4.0, and formally prove its security in the random oracle model. Compared with previous schemes, it has three advantages: 1) All eleven state-of-the-art criteria are achieved; 2) Its computation cost on sensor nodes is comparable to those insecure schemes that employ only symmetric cryptographic algorithms, and is superior to those that also use asymmetric cryptographic algorithms; 3) It takes the advantage of the computation and storage capabilities of the cloud center to achieve user anonymity and the resistance to offline dictionary attack without performing any asymmetric cryptographic algorithms on gateways. Our computation cost on gateways is the smallest among all state-of-the-art relevant schemes for comparison.

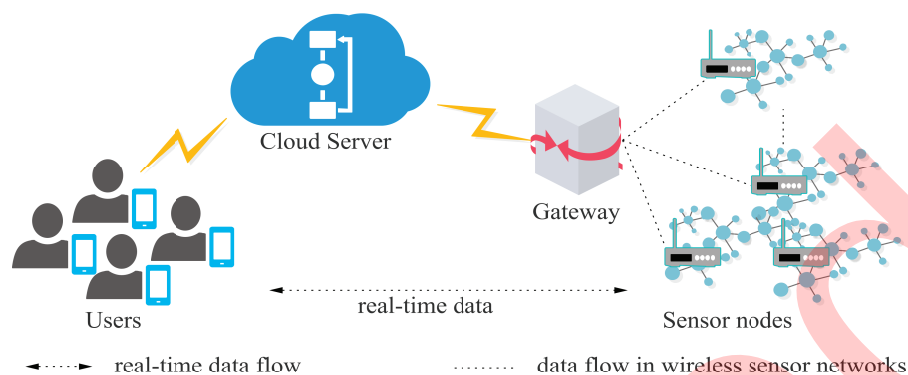
**Keywords** Industry 4.0, Wireless sensor networks, Password authentication, Forward Secrecy, Offline dictionary attack

**Citation** C. Wang, D. Wang, G. Xu, D. He. Efficient Privacy-Preserving User Authentication Scheme with Forward Secrecy for Industry 4.0. Sci China Inf Sci, for review

1 Introduction

Industry 4.0 is “fully-integrated, collaborative manufacturing system that responds in real time to meet changing demands and conditions in the factory, in the supply network and in customer needs” [1]. It is a new phase of industrial revolution, and offers a more comprehensive, interlinked and holistic approach for manufacturing by taking full advantage of the combination of information communication technology and information-physical systems [2]. As shown in Fig. 1, one of the critical network infrastructures of industry 4.0 is the wireless sensor network (WSN). It is used in industry 4.0 systems with cloud computing technology [3, 5, 7] to collect data from environment and automatically build learning models for promoting industrial intelligence. Generally, a WSN is formed by lots of distributed sensor nodes and

\* Corresponding author (email: wangding@nankai.edu.cn)



**Figure 1** System Architecture of Industry 4.0.

a gateway node. The sensor nodes are resource-constrained device with limited computation and storage capabilities [4, 6, 8].

In some industry 4.0 applications, users may need to access the real-time data stored in sensor nodes. For example, in a production maintenance system of industry 4.0, normally, the sensor nodes will monitor the key parts of industrial machines and submit the collected data to the cloud center periodically. Then, the data will be analyzed, the use status of the machines is to be judged, and whether it needs to be sent to professional staff for maintenance is determined. Once there is any problem with the machines, the cloud center can make decisions timely to avoid an emergency shutdown. In this application, it is natural that the user (professional staff) wants to directly access the real-time data in a specific sensor node to further diagnose the system's failures or check the system's maintenance status by sampling. Generally, these industry 4.0 applications are security-critical with massive amounts of sensitive data, thus they are the target of many adversaries. As such, it is important to protect sensitive data stored in sensor nodes from unauthorized access, an authentication mechanism is required to identify the authenticity of users, and a session key is necessary to be provided to secure their conversations. In a user authentication mechanism, there are three factors to authenticate a user: 1) something that the user knows, such as password [9]; 2) something that the user has, such as smart card [10, 11]; 3) something that the user is, such as biometrics or behavior trait [12, 13]. A multi-factor user authentication scheme combines at least two factors.

One of the important attributes of user authentication for industry 4.0 is forward secrecy (also known as perfect forward secrecy). It guarantees that the agreed session keys will not be compromised even if the private key of gateways or sensor nodes is compromised. It can protect the past conversations against future compromises of secret keys [14]. Prior to the implementation of forward secrecy, all data transmitted between a user and a sensor node could be compromised if the private keys of gateways or sensor nodes were ever disclosed. One famous example of such an attack is the Heartbleed bug [15], which allows the adversary to read the memory of the systems. Forward secrecy greatly improves systems' ability to resist risks. It ensures that, in the worst case, at least previous conversations are secure. New security standards, such as WiFi WPA3 [16] and TLS 1.3 [17], begin to take forward secrecy as an important feature of authentication protocols.

### 1.1 Related Work

In 2009, the first smart-card-based password authentication protocol for WSNs was proposed by Das et al. [18], where no public-key algorithm is involved. However, their scheme was shortly shown that it is subject to offline dictionary attack and fail to build a session key to protect conversations between users and sensor nodes. Then Fan et al. [19] designed a new privacy-preserving scheme using hash and exclusive-OR operations. Unfortunately, Wang et al. [20] proved that this scheme cannot preserve forward secrecy and suffers from various attacks. Because their sensor nodes have the same secret key, and the session key is an outcome of the secret key and parameters transmitted in open channel, the adversary who gets the secret key can get the session key and break the forward secrecy successfully. Next, Das et

al. [21] presented a new user authentication scheme that supports dynamic nodes addition. Once again, this scheme subsequently was found to have various security problems, including failing to achieve forward secrecy. For example, in their scheme, all parameters that are contained in the session key are encrypted using the secret key of the target sensor node. Therefore, the adversary who obtains the key can decrypt to get these parameters and then compute the session key correctly. In 2013, Xue et al. [22] proposed a secure scheme for WSNs, but failed again. To provide forward secrecy, they let users and sensor nodes choose a random number and jointly produce the session keys. However, the adversary who obtains the gateway's secret key can successfully calculate the session key in combination with the parameters in the public channel, thereby invalidating forward secrecy. Furthermore, Wang et al. [20] show that their scheme cannot preserve user anonymity. In conclusion, researchers are committed to breaking previous schemes and then proposing new secure protocols using lightweight symmetric cryptographic techniques. However, most attempts have failed and most schemes cannot achieve forward secrecy.

Recently, Wang et al. [20] and Ma et al. [23] demonstrate that lightweight public-key algorithms are indispensable to resist offline dictionary attacks and realize user anonymity in multi-factor user authentication protocols. Besides, to provide forward secrecy, the sensor nodes have to conduct at least two modular exponentiation or point multiplication operations. Following these principles, many public-key-algorithm-based schemes are proposed. For example: in 2014, Choi et al. [24] presented an authentication scheme based on elliptic-curve-cryptography (ECC), but their scheme cannot achieve user anonymity and suffers from offline dictionary attack. In 2015, He et al. [25] designed a discrete-logarithm-based authentication scheme, but it cannot preserve user anonymity and forward secrecy. In 2016, Reddy et al. [26] also presented an ECC-based three-factor authentication scheme. Unfortunately, it still cannot resist offline dictionary attack, and its computational cost on sensor nodes and gateways are still high. In 2017, Jiang et al. [27] designed an improved scheme that aims to overcome offline dictionary attack, but their attempt failed again. In 2018, an ECC-based provable secure scheme was introduced by Li et al. [3], but it is not secure against offline dictionary attack and achieves forward secrecy with two point multiplication operations at sensor nodes. In brief, some of schemes which employ public-key algorithms to enhance the security, still have this or that weaknesses, and they always have high computational cost: the sensor nodes need to run two modular exponentiation or point multiplication operations, and the gateway needs to run one modular exponentiation or point multiplication operation.

1.2 Motivations and Contributions

Research over the past decade has shown that designing a secure user authentication protocol for an industry 4.0 environment is very difficult. Generally, sensor node has limited resources and it is difficult to perform computational expensive cryptographic primitives. On the other hand, the application scenarios of industry 4.0 often have high security and performance requirements on user authentication schemes. In particular, among many security requirements, the resource-constrained nature of sensor nodes brings greater challenges to the realization of forward secrecy. In addition, as the number of remote users and connected sensor nodes increases, the number of concurrent sessions becomes larger, and then the lack of computation and storage capabilities of gateways become more apparent. However, we find that most of the existing protocols only use lightweight symmetric cryptographic algorithms to cater for the resources-constrained nature of sensor devices, but this type of protocols violates the protocol design principles (i.e. asymmetric cryptographic algorithms are indispensable to design secure protocols [23, 28]), so these protocols is inherently unable to achieve forward secrecy and resist offline dictionary attacks. Remaining protocols that follow the protocol design principles employ asymmetric cryptographic algorithms to achieve better security, but such protocols need to perform at least two modular exponentiation or elliptic curve point multiplication operations at sensor nodes, and at least one modular exponentiation or elliptic curve point multiplication operation at gateways, which are inefficient.

Besides, the cloud center is usually the key computing center for intelligent decision-making of the entire system in industry 4.0 systems. Users often need the cloud center to provide various services to assist industrial intelligent production. Therefore, user authentication protocols can leverage the powerful computation and storage capabilities of the cloud center to well balance the security and performance.

However, existing related protocols do not take the cloud center into account, thus they do not conform to the development trend of industry 4.0 systems in terms of system architecture, nor do they take the advantage of the powerful capabilities of the cloud center to alleviate the computing pressure of gateways.

Therefore, this paper attempts to propose a user authentication scheme that can cater to the development trend of industry 4.0 systems, balancing the conflict between the security and performance, so that users are able to access real-time data stored in sensor nodes securely. Our contributions are threefold:

- 1). We depict the multi-factor user authentication model for industry 4.0 systems, this authentication model can take the full advantage of the computation and storage capabilities of the cloud center and it is suitable for industry 4.0 environments.
- 2). We exploit the imbalanced computational nature of the Rivest Shamir Adleman (RSA) cryptosystem to provide forward secrecy without expensive computation cost on the sensor nodes. Through taking advantages of the computation and storage capabilities of the cloud center, we achieve user anonymity and the resistance to offline dictionary attack without performing asymmetric cryptographic algorithms on the gateway.
- 3). We formally prove the scheme's security under random oracle model and compare it with relevant typical authentication schemes. The results demonstrate that our scheme meets all eleven state-of-the-art evaluation criteria with minimal computation cost on the gateway and very small computation cost on the sensor nodes, is especially suitable for industry 4.0 applications with a large number of resource-constrained sensor nodes.

**Table 1** Notations and Abbreviations

| Symbol        | Description            | Symbol           | Description                      |
|---------------|------------------------|------------------|----------------------------------|
| $U_i$         | $i^{th}$ user          | $S_j$            | $j^{th}$ sensor node             |
| $GW N_k$      | $k^{th}$ gateway       | $GID_k$          | the identity of $GW N_k$         |
| $\mathcal{A}$ | the adversary          | $CS$             | the cloud center                 |
| $ID_i$        | identity of $U_i$      | $Enc/Dec(\cdot)$ | encryption/decryption function   |
| $PW_i$        | password of $U_i$      | $Gen/Rep(\cdot)$ | fuzzy extractor                  |
| $fn g_i$      | biometric of $U_i$     | $h(\cdot)$       | one-way hash function            |
| $SID_j$       | identity of $SN_j$     | $x$              | $CS$ 's long term secret key     |
| $X_{S_j}$     | secret key of $S_j$    | $x_{G_k}$        | $GW N_k$ 's long term secret key |
| $X_{G_k}$     | secret key of $GW N_k$ | $SK$             | session key                      |
| $\oplus$      | XOR operation          | $\parallel$      | concatenation operation          |
| $\rightarrow$ | a public channel       | $\Rightarrow$    | a secure channel                 |

## 2 Preliminaries

This section shows the authentication architecture, adversary model, and evaluation criteria of our proposed scheme. Note that Table 1 summarize the notations and abbreviations of this paper.

### 2.1 Authentication Architecture

As shown in Fig. 2, to ensure that real-time data can be accessed securely by users, four participants are involved in user authentication schemes: the users with a smart terminal (usually is a smart phone) that supports password-based authentication, cryptographic computation and biometric extraction, a cloud center with powerful computation and storage capabilities, a gateway with relatively limited resource and lots of resource-constrained sensor nodes. Besides, four basic phases are included: registration, login,



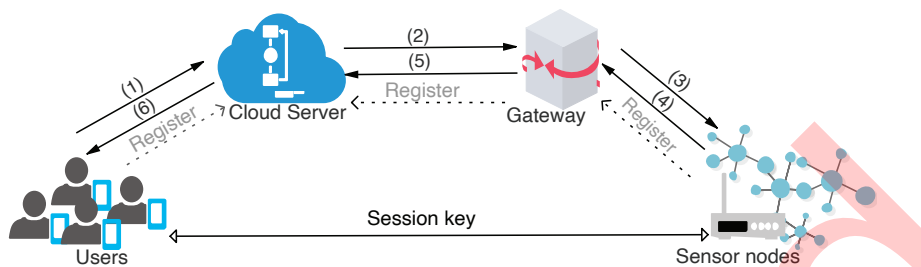


Figure 2 Authentication Architecture of Industry 4.0.

authentication and password change phase. Usually, dynamics node addition phase and re-registration phase are provided to achieve the repairability and extensibility of the authentication scheme. At the beginning, both the cloud center  $CS$  and the gateway  $GW N_k$  will get their long term secret key  $x$  and  $x_{G_k}$ , respectively. In the registration phase, the user  $U_i$  and the gateway  $GW N_k$  need submit their personal information to register to the cloud center  $CS$ , and the sensor node  $S_j$  needs submit its identity to  $GW N_k$ . This phase takes place in a secure channel  $\Rightarrow$ . After the registration phase,  $U_i$  has some sensitive parameters stored in her smart phone and shares a secret parameter with  $CS$ ;  $GW N_k$  and  $CS$  will form a secret shared key  $X_{G_k}$  (also called as  $GW N_k$ 's secret key);  $S_j$  and  $GW N_k$  will share a secret key  $X_{S_j}$  (also called as  $S_j$ 's secret key). Then the user  $U_i$  will choose a target sensor node  $S_j$  and initiates a login request to  $CS$  via a public channel  $\rightarrow$ . Then  $U_i$  and  $S_j$  will authenticate each other and negotiate a session key to protect their subsequent communications. Furthermore, the user can update her password in password change phase, and re-register to the system in re-registration phase if her account is blocked.

2.2 Adversary Model and Evaluation Criteria

A well-defined evaluation criteria and adversary model put authentication schemes on a common spectrum, which makes it possible to assess the schemes fairly and comprehensively. Recently, Wang et al. [6] give a systematic and widely-accepted adversary model and evaluation criteria for WSNs. According to Wang et al.'s adversary model [6] which is developed from Dolev-Yao [41], we form ours as follows:

- D1.  $\mathcal{A}$  can enumerate all user-chosen passwords and identities within polynomial time; or know the victim's identity when assessing the security of the scheme.
- D2.  $\mathcal{A}$  can intercept, modify, eavesdrop all the messages that are transmitted in a public channel among the users, cloud center, gateway and sensor nodes. Note that, in registration phase, the channel is supposed to be secure.
- D3.  $\mathcal{A}$  can break any two of the three factors (password, smart card/smart terminal and biometrics).
- D4.  $\mathcal{A}$  can obtain the previous session keys between users and sensor nodes.
- D5.  $\mathcal{A}$  can get the secret key of the cloud center, the gateway or the sensor nodes when considering forward secrecy.
- D6.  $\mathcal{A}$  can capture the data stored in some sensor nodes.
- D7.  $\mathcal{A}$  can register as a legitimate user, gateway or sensor node. In other words, theses three participants will try to get additional data or privileges, but they will still follow the protocol.

According to Wang et al.'s twelve independent evaluation criteria [6], we form ours as shown in Fig. ?? . Among these criteria, "forward secrecy" and "resistance to smart card loss attack" are most two difficult criteria to be achieved. Smart card loss attack is the most prevalent [20]. Forward secrecy is of significant to high security requirement applications, it can improve the system's resistance to the final attack. To resist smart card loss attack, the "fuzzy-verifier" techniques and public-key techniques are necessary [10]. Yet, when applying public-key techniques, most of schemes require gateways to conduct at least one modular exponentiation or point multiplication operation, which can be a computing bottleneck with the number of concurrent sessions increasing. To achieve forward secrecy, as least two modular exponentiation or point multiplication at sensor nodes is indispensable [23]. However, due to the resource-constrained nature of sensor nodes, computational expensive cryptographic primitive on sensor nodes is

**Table 2** Evaluation Criteria [6]

| Short term                          | Definition                                                                                                                      |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| $C1$ : No Password Verifier-table   | $CS$ and $GW N_k$ should not store any password-related data.                                                                   |
| $C2$ : Password Friendly*           | $U_i$ is able to choose her password and change it locally.                                                                     |
| $C3$ : Sound Repairability          | The dynamic node addition and user re-registration phase is provided.                                                           |
| $C4$ : Key Agreement                | The sensor node and the user should share a same session key for future communication after the authentication.                 |
| $C5$ : No clock synchronization     | The participants do not have to keep a same time clock.                                                                         |
| $C6$ : No Password Exposure         | $CS$ cannot get/compute user's password.                                                                                        |
| $C7$ : Mutual Authentication        | All the participants should authenticate each other.                                                                            |
| $C8$ : User Anonymity               | User's identity should not be exposed to the adversary.                                                                         |
| $C9$ : No Smart Card Loss Attack    | The adversary cannot conduct an attack by making use of the data stored in smart cards/smart terminals.                         |
| $C10$ : Resistance to Known Attacks | The adversary without smart card/smart terminals cannot carry out known attacks in TABLE 1 of [6], such as node capture attack. |
| $C11$ : Forward Secrecy             | The adversary is impossible to get the previous session keys, even getting the long term secret key.                            |

not practical. Thus, how to achieve forward secrecy efficiently is still an open issue. Most schemes either ignore the resource limitation nature of sensor nodes or attempt to only use lightweight operations (these schemes usually cannot provide forward secrecy). In this paper, taking the advantage of the imbalanced computational nature of RSA cryptosystem, we try to achieve forward secrecy efficiently.

### 3 Formal security model

Provable security theory has been one of the most effective ways of analyzing the security of complex protocols. Based on [9,10], this section defines the security model to formally capture adversary's capabilities and possible attack processes.

**Players.** In our four-party-protocol  $\mathcal{P}$ , the participants involved are: a user  $U \in \text{User}$ , a cloud center  $CS \in \text{CloudServer}$ , a gateway  $G \in \text{Gateway}$  and a sensor node  $S \in \text{Sensor node}$ . When specific to a conversation,  $U$  is instantiated as  $U_i$ , similarly,  $G \Rightarrow G_k$ ,  $CS \Rightarrow CS_m$  and  $S \Rightarrow S_j$ ,  $i, j, k, m \in \mathbb{Z}$ . Let  $I$  be any kind of instances, and  $I^s$  be the  $s$ -th instance of  $I$ .

**Long-lived keys.** Before the authentication, the four participants need to build their basis of trust firstly in registration phase. Generally, the cloud center owns a long-term secret key  $cpr_{key}$ . To a scheme using public-key algorithm, there is also a corresponding public key  $pub_{key}$ . Then the gateways have their secret key  $gwn_{key}$  stored in database; users will also get their unique secret key  $ue_{key}$  which is not stored at the user side, but can be computed by the user's passwords and parameters in smart terminal. Note that, in our four-party system, the gateway also owns a long-lived key  $gpri_{key}$ , and it will distribute the sensor nodes their unique secret key  $sen_{key}$ . The cloud center and the gateway do not directly store  $\{sen_{key}, ue_{key}\}$  and  $gwn_{key}$ , respectively, but the parameters that can derive them.

**Queries.**  $\mathcal{A}$  can only interact with the protocol participants via oracle queries. The queries can capture the adversary capabilities in a real attack and are defined as follows.

- $Execute(U_i^r, CS_m^d, G_k^s, S_j^t)$ : this query outputs the transcript among the four instances. It models a passive attack (usually is eavesdropping).
- $Send(I, I_i^s, m)$ : this query means that  $I$  sends the message  $m$  to instance  $I_i^s$ , and  $I$  gets a response from  $I_i^s$  according to  $\mathcal{P}$ . But if  $m$  is invalid, this query is ignored.



- $Reveal(I_j^s)$ : it models known-key attack where  $I$  can be  $U$  or  $S$ . If  $I^s$  has negotiated a session key, then the oracle outputs the key, otherwise  $\perp$ .
- $Corrupt(I, a)$ : It models  $\mathcal{A}$ 's corruption capability and is defined as follows:
  - (a) when  $I == U_i$ ,  $\mathcal{A}$  can break any two of the three factors.
    - If  $a = 1$ ,  $\mathcal{A}$  gets the password  $PW_i$  and the biometric  $fng_i$ , written as  $[output(PW_i, fng_i)]$ ;
    - If  $a = 2$ ,  $\mathcal{A}$  gets the password and the data in smart terminal, written as  $[output(SC_i, PW_i)]$ ;
    - If  $a = 3$ ,  $\mathcal{A}$  gets the biometric and the data in smart terminal, written as  $[output(fng_i, SC_i)]$ .
  - (b) when  $I == CS_m$ , output secret key  $\{x, y\}$  and verifier table  $\{ID_i, x_i, SUM\}$ , denoted as  $[output(x, y, verifier\ table)]$ .
  - (c) when  $I == G_k$ , output secret key  $x_{G_k}$  and  $X_{G_k}$ , denoted as  $[output(x_{G_k}, X_{G_k}, verifier\ table)]$ .
  - (d) when  $I == S_j$ , output the shared secret key  $X_{S_j}$  of  $S_j$ , written as  $[output(X_{S_j})]$ .
- $Test(I_j^s)$ : It does not aim at modeling the attack, but testing the semantic security of session key. If  $I_j^s$  has not yet built a session key or  $I_j^s$  is not fresh, or  $Test(I_j^s)$  has been queried before, then the answer is  $\perp$ ; otherwise, the oracle will flip a coin  $b$ . If  $b == 1$ , it outputs the real session key; if  $b == 0$ , it outputs a random number with the same size.

**Partnering.** The session identifier  $sid$  is used to define partnering. Suppose there are two instances  $U_i^s$  and  $S_j^r$ , then two instance  $U_i^s$  and  $S_j^r$  are partnered only if the following conditions are satisfied:

- they are accepted.
- $sid\ U_i^s == sid\ S_j^r$  where  $sid\ U_i^s$  or  $sid\ S_j^r$  denotes the session identifier of  $U_i^s$  or  $S_j^r$ .
- $pid\ U_i^s == S_j^r$ ,  $pid\ S_j^r == U_i^s$ , where  $pid\ U_i^s$  denotes the session identifier of  $U_i^s$ 's partner.

**Freshness.** Generally, the adversary's goal is to guess the value of  $b$  in  $Test(I_j^s)$  to break the semantic security. However, suppose a situation where  $\mathcal{A}$  queries  $Reveal(I_j^s)$  and  $Test(I_j^s)$  at the same time, then  $\mathcal{A}$  of course can judge the value of  $b$ . Note that in this situation,  $\mathcal{A}$  actually dose not break the semantic security. Therefore, it is necessary make some restrictions to allow  $\mathcal{A}$  to query  $Test(I_j^s)$  reasonably. So we define the notion of freshness. A fresh instance  $I$  should satisfy:

- $I$  has accepted and gotten the session key.
- $\mathcal{A}$  has not yet asked  $Reveal$  query for  $I$  and its partner.
- $Corrupt(U, a)$  is queried no more than one time.
- $Corrupt(CS, 1)$  is not asked. Or though it is asked,  $\mathcal{A}$  does not query  $Send$ -query after that.
- $Corrupt(S, 1)$  is not asked. Or though it is asked,  $\mathcal{A}$  does not query  $Send$ -query after that.
- $Corrupt(G, 1)$  is not asked. Or though it is asked,  $\mathcal{A}$  does not query  $Send$ -query after that.

**Correctness.** If  $U_i$ ,  $CS_m$ ,  $S_j$  and  $G_k$  are partnered and accepted,  $U_i$  and  $S_j$  will share a session key.

**Semantic Security:** Consider a protocol  $\mathcal{P}$ , there is an adversary  $\mathcal{A}$  who has asked  $Execute$ ,  $Send$ ,  $Reveal$  queries with a polynomial number, as well as a  $Test$ -query to fresh instances.  $\mathcal{A}$  tries to against  $\mathcal{P}$  via guessing the value of  $b$ . Let  $Succ$  be the event that  $\mathcal{A}$  guessed  $b$  correctly. The advantage of  $\mathcal{A}$  in breaking semantic security of  $\mathcal{P}$  is:  $Adv_{\mathcal{P}, \mathcal{D}}^{sfs-ake} \mathcal{A} = 2Pr[Succ \mathcal{A}] - 1$ .

We say a password-authenticated protocol is semantically secure, when in the polynomial time, the advantage of an adversary  $\mathcal{A}$  who makes at most  $q_{send}$  active attacks, satisfies:

$$Adv_{\mathcal{P}, \mathcal{D}}^{ake}(\mathcal{A}) < C' q_{send}^{s'} + \varepsilon(\ell)$$

where  $\mathcal{D}$  is the password space whose frequency distribution follows a Zipf's law [29],  $C'$  and  $s'$  are Zipf parameters [10],  $\varepsilon(\cdot)$  is a negligible function, and  $\ell$  is a system security parameter.

#### 4 The proposed scheme

This section introduces an efficient and secure three-factor remote user authentication scheme which is suitable to a cloud-aided industry 4.0 environment. We exploit the imbalanced computational nature of the RSA cryptosystem to provide forward secrecy without expensive computation cost on the sensor nodes. In the RSA algorithm, the public key  $e$  is recommended to be a small prime (e.g.,  $2^{16} + 1$ ), the operation  $m^e \bmod n$  costs less than the operation  $g^a \bmod p$  in ElGamal cryptosystems (or  $aP$  operations

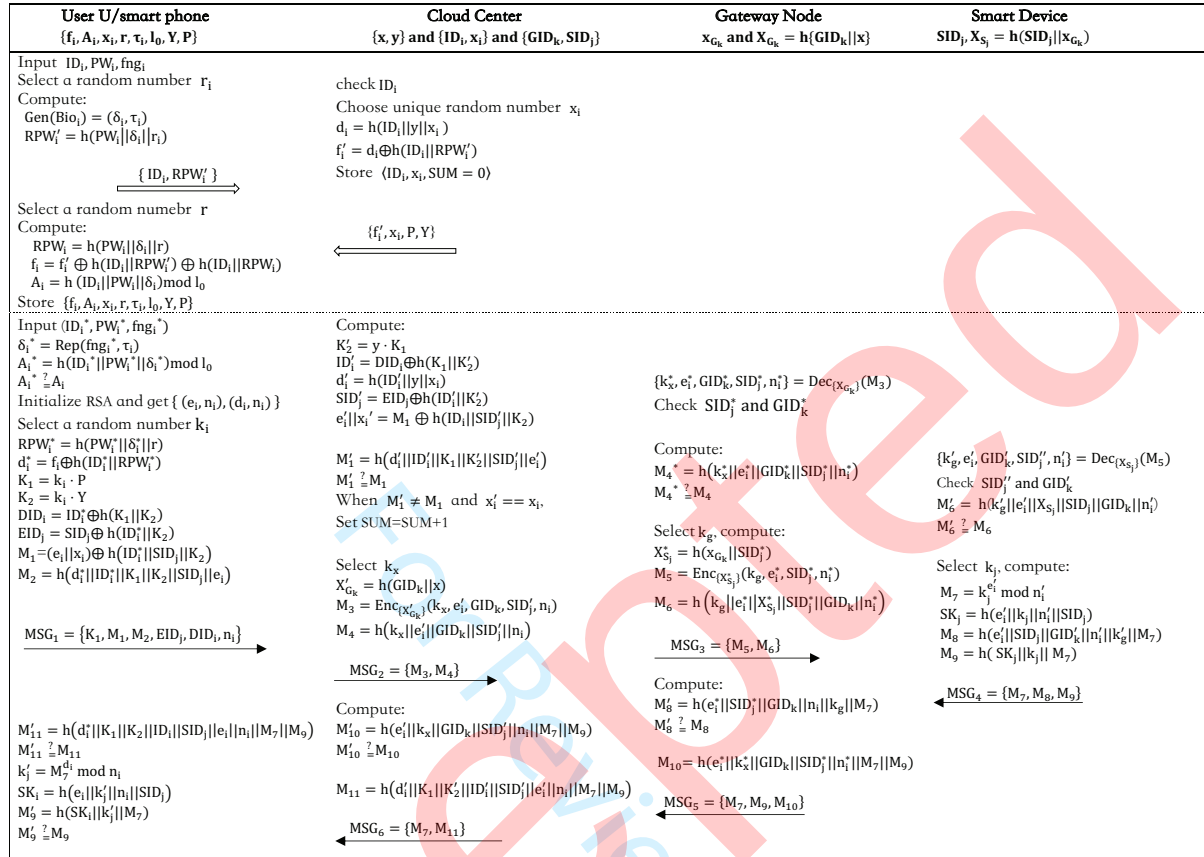


Figure 3 The Proposed Scheme.

in ECC cryptosystems) where  $a$  has a large bit length to ensure security. The RSA cryptosystem is shown as follows:

- Key generation. Select two distinct prime numbers  $(p, q)$ , compute  $n = p \cdot q$ ,  $r = (p - 1)(q - 1)$ ,  $d \equiv e^{-1} \bmod r$ , where  $e$  is an integer satisfying  $1 < e < r$  ( $e$  and  $r$  are coprime). The public key is  $(n, e)$ , the private key is  $(n, d)$ .
- Encryption.  $c \equiv m^e \bmod n$ .
- Decryption.  $c^d \equiv (m^e)^d \equiv m \bmod n$ .

#### 4.1 Sensor node and Gateway Registration Phase

Since we regard the user, the cloud center and the gateway are three different stakeholders. To better security, we do not put the eggs in a basket. In other words, we let the cloud center has two long term secret key  $x$  and  $y$ .  $x$  is used to compute secret parameters between gateways and the cloud center; and  $y$  is to compute secret parameters between users and the cloud center. Thus, once one of the keys is exposed, only one of the stakeholders (the user or the gateway) will be affected. Besides, the gateway also has two secret keys, one is  $X_{G_k}$  ( $= h(GID_k || x)$ ), the other is  $x_{G_k}$ .  $X_{G_k}$  is shared with the cloud center. Note that, each gateways have their own unique shared secrecy key. Therefore, the security of the gateways will not be affected by each other.  $x_{G_k}$  is applied to the network that consists of the gateway and the sensor nodes, which guarantees the independence of wireless sensor network. In our scheme, the users and the gateways need to register to the cloud center, and the sensor nodes need to register to the gateways. Note that, we build the scheme on an elliptic curve  $E$ . To an elliptic curve  $E$  over prime finite field  $F_p$ , we have:  $y^2 = x^3 + ax + b \bmod p$ , where  $a, b \in F_p$ , and  $4a^3 + 27b^2 \neq 0 \bmod p$ . Assume  $P$  is a point on  $F_p$ ,  $aP$  is the result of computing  $P$  times  $a$ . The cloud center select  $x$  and  $y$  as its long term secret key, the public key is  $Y = y \cdot P$ . In addition, the hash function  $h : 0, 1^* \rightarrow 0, 1^l$  with the

input  $s \in 0, 1^*$  and output  $t \in 0, 1^l$ , should satisfied the following properties: 1) given  $s$ , it can compute  $t$  such that  $t = h(s)$  within polynomial time; 2) given  $t$ , it should be computationally infeasible to find the input  $s$  such that  $t = h(s)$ ; 3) given  $s$ , it should be computationally infeasible to find  $s' (s' \neq s)$  such that  $h(s') = h(s)$ .

The sensor node can register to the gateway according to the following steps:

Step 1.  $S_j \Rightarrow GWN_k$ : registration request.

Step 2.  $GWN_k \Rightarrow S_j$ :  $\{SID_j, X_{S_j} = h(SID_j || x_{G_k})\}$ , where  $x_{G_k}$  is  $GWN_k$ 's secret key.

Step 3.  $S_j$  stores  $X_{S_j}$ .

The gateway can register to the cloud center as the steps below:

Step 1.  $GWN_k \Rightarrow CS$ : registration request and the identity of the sensor nodes that connected to it.

Step 2.  $CS \Rightarrow GWN_k$ :  $\{GID_k, X_{G_k} (= h(GID_k || x))\}$ , the cloud center store the identity of the gateway and its corresponding sensor nodes as  $\{GID_k, SID_j\}$ .

Step 3.  $GWN_k$  keeps  $X_{G_k}$ .

## 4.2 User Registration Phase

Step 1.  $U_i \Rightarrow CS$ :  $\{ID_i, RPW'_i\}$ .

$U_i$  inputs her selected identity  $ID_i$  and password  $PW_i$  and biometric  $fng_i$ , then submits  $\{ID_i, PW_i, fng_i\}$  to the smart phone. Then it selects a random number  $r_i$  and computes:  $Gen(fng_i) = (\delta_i, \tau_i)$ ,  $RPW'_i = h(PW_i || \delta_i || r_i)$ .

Step 2.  $CS \Rightarrow U_i$ :  $\{f'_i, x_i, P, Y\}$ .

The cloud center first checks the valid of the identity  $ID_i$ , then picks a unique random number  $x_i$  for  $U_i$ , and computes  $d_i = h(ID_i || y || x_i)$ ,  $f'_i = d_i \oplus h(RPW'_i || ID_i)$ , then stores  $\{ID_i, x_i, SUM = 0\}$  in the database.

Step 3. After getting the response, the smart terminal computes:  $RPW_i = h(PW_i || \delta_i || r)$  using a new random number for stopping insider attack [30],  $f_i = f'_i \oplus h(ID_i || RPW_i) \oplus h(ID_i || RPW_i)$ ,  $A_i = h(ID_i) || (h(PW_i) || h(\delta_i)) \bmod l_0$  where  $l_0 = 2^8$ , then keeps  $\{f_i, A_i, A_i \oplus x_i, r, \tau_i, Y, P, l_0\}$ .

Here we apply Wang et al.'s method [10] to deal with the conflict between detecting the wrong input timely and resisting to offline dictionary attack. More specifically, we let the verifier  $A_i$  be computed as  $h(ID_i || PW_i || \delta_i) \bmod l_0$ . In this way, even an adversary acquires the victim's biometric and finds a pair of identity and password  $\{ID_i^*, PW_i^*\}$  that satisfies the equation  $h(ID_i^* || PW_i^* || \delta_i) \bmod l_0$ , she still has to further check its correctness online because there are  $\frac{|D_{id} * D_{pw}|}{l_0} \approx 2^{32}$  candidate pairs that satisfy the equation when  $l_0 = 2^8$ . However, the online guessing attack can be prevented by the parameter "SUM" which is used to count the failure times of the authentication. Once its value exceeds the preset value (such as 10), then the user's account will be suspended. Accordingly, our scheme detect the wrong input timely, and also resist offline dictionary attack caused by the verifier  $A_i$ .

## 4.3 Login Phase

Step 1.  $U_i \rightarrow CS$ :  $\{K_1, M_1, M_2, EID_j, DID_i, n_i\}$ .

$U_i$  enters  $\{ID_i^*, PW_i^*, fng_i^*\}$ , and then the smart terminal computes:  $\delta_i^* = Rep(fng_i^*, \tau_i)$ ,  $h(ID_i^* || PW_i^* || \delta_i) \bmod l_0$ , then checks whether  $A_i^* \stackrel{?}{=} A_i$  to authenticate the user.

If equation does not hold, the smart terminal rejects the request. Otherwise, it initializes a pair of RSA parameter  $\{(e_i, n_i), (d_i, n_i)\}$ , chooses a random number  $k_i$ , computes:  $RPW_i^* = h(PW_i^* || \delta_i^* || r)$ ,  $d_i^* = f_i \oplus h(ID_i^* || RPW_i^*)$ ,  $K_1 = k_i \cdot P$ ,  $K_2 = r_i \cdot Y$ ,  $DID_i = ID_i^* \oplus h(K_1 || K_2)$ ,  $EID_j = SID_j \oplus h(ID_i^* || K_2)$ ,  $M_1 = e_i || x_i \oplus h(ID_i^* || SID_j || K_2)$ ,  $M_2 = h(d_i^* || ID_i^* || K_1 || K_2 || SID_j || e_i)$ .

## 4.4 Authentication Phase

Step 1.  $CS \rightarrow GWN_k$ :  $\{M_3, M_4\}$ .

Once receiving the login request, the cloud center computes  $K'_2 = y \cdot K_1$ ,  $ID'_i = DID_i \oplus h(K_1 || K'_2)$ , retrieves  $x_i$  from the database, then computes  $d'_i = h(ID'_i || y || x_i)$ ,  $SID'_j = EID_j \oplus h(ID'_i || K'_2)$ ,  $e'_i || x'_i = M_1 \oplus h(ID'_i || SID'_j || K_2)$ ,  $M'_1 = h(d'_i || ID'_i || K_1 || K'_2 || SID'_j || e'_i)$ .

If  $M'_1 \neq M_1$ , the cloud center rejects the request and checks the value of  $x'_i$  and  $x_i$ . If  $x'_i = x_i$ , and the cloud center sets  $SUM = SUM + 1$ . Once  $SUM$  exceeds a preset value (such as 10), the cloud center will suspend  $U_i$ 's account.

If  $M'_1 = M_1$ , the cloud center thinks the request is valid, then selects a random number  $k_x$ , and determines the corresponding gateway  $GWN_k$ , then computes  $X'_{G_k} = h(GID_k || x)$ ,  $M_3 = Enc_{X'_{G_k}}(k_x, e'_i, GID_k, SID'_j, n_i)$ ,  $M_4 = h(k_x || e'_i || GID_k || SID'_j || n_i)$ .

Step 2.  $GWN_k \rightarrow S_j: \{M_5, M_6\}$ .

The gateway decrypts  $M_3$  with  $X'_{G_k}$  to get  $\{k_x^*, e_i^*, GID_k^*, SID_j^*, n_i^*\}$ . After checking the valid of  $\{GID_k^*, SID_j^*\}$ , the cloud center computes  $M_4^* = h(k_x^* || e_i^* || GID_k^* || SID_j^* || n_i^*)$ .

If  $M_4^* \neq M_4$ ,  $GWN_k$  rejects the session. Otherwise, it selects a random number  $k_g$ , and computes:  $X_{S_j}^* = h(x_{G_k} || SID_j^*)$ ,  $M_5 = Enc_{X_{S_j}^*}(k_g, e_i^*, SID_j^*, n_i^*)$ ,  $M_6 = h(k_g || e_i^* || X_{S_j}^* || SID_j^* || GID_k || n_i^*)$ .

Step 3.  $S_j \rightarrow GWN_k: \{M_7, M_8, M_9\}$ .

The sensor node decrypts  $M_5$  using its private key  $X_{S_j}$ , gets  $\{k_g', e'_i, GID'_k, SID'_j, n'_i\}$ , checks the valid of  $GID'_k$  and  $SID'_j$ . Then, the sensor node computes  $M'_6 = h(k_g' || e'_i || X_{S_j} || SID'_j || GID_k || n'_i)$ .

If  $M'_6 \neq M_6$ , the sensor node rejects the access. Otherwise, it computes  $M = k_j^{e'_i} \bmod n'_i$ ,  $SK_j = h(e'_i || k_j || n'_i || SID_j)$ ,  $M_8 = h(e'_i || SID_j || GID'_k || n'_i || k_g' || M_7)$ ,  $M_9 = h(SK_j || k_j || M_7)$ .

Step 4.  $GWN_k \rightarrow CS: \{M_7, M_9, M_{10}\}$ .

The gateway computes  $M'_8 = h(e_i^* || SID_j^* || GID_k || n_i || k_g || M_7)$ , compares  $M'_8$  with  $M_8$  to authenticate  $S_j$ . If the equation does not hold, terminates the session, otherwise computes  $M_{10} = h(e_i^* || k_x^* || GID_k || SID_j^* || n_i^* || M_7 || M_9)$ .

Step 5.  $CS \rightarrow U_i: \{M_7, M_{11}\}$ .

The cloud center computes  $M'_{10} = h(e_i^* || k_x || GID_k || SID_j^* || n_i || M_7 || M_9)$ . If  $M'_{10} \neq M_{10}$ , ends the session; Otherwise, computes  $M_{11} = h(d_i^* || K_1 || K_2 || ID_i^* || SID_j^* || e_i^* || n_i || M_7 || M_9)$ .

Step 6. The smart terminal computes  $M'_{11} = h(d_i^* || K_1 || K_2 || ID_i^* || SID_j^* || e_i^* || n_i || M_7 || M_9)$ . If  $M'_{11} \neq M_{11}$ , the smart terminal terminates the session and the authentication fails. According to the RSA algorithm, when the ciphertext is  $c$ , the plaintext is  $m$  and the pair of public/private key is  $((e, n), (d, n))$ , it has  $c^d \bmod n = (m^e)^d \bmod n$ . Therefore, the user can use the private key  $d_i$  to decrypt  $M_7$ , and get  $k_j'$  by computing  $M_7^{d_i} \bmod n_i$ , after that, the user computes the session key  $SK_i = h(e_i || k_j' || n_i || SID_j)$ ,  $M'_9 = h(SK_i || k_j' || M_7)$ . If  $M'_9 = M_9$ , it means that the user and the sensor node have share a same session key and the authentication is finished successfully. Note that, all the participants should delete the RSA parameters. Otherwise, the user ends the session and rejects the session key.

#### 4.5 Password Change Phase

Step 1.  $U_i \rightarrow$  smart terminal:  $\{ID_i^*, PW_i^*, fng_i^*, PW_i^{new}\}$ .

Step 2. The smart terminal will firstly verify the identity of the user: computes  $\delta_i^* = Rep(fng_i^*, \tau_i)$ ,  $A_i^* = h(ID_i^* || PW_i^* || \delta_i^*) \bmod l_0$ , compares  $A_i^*$  with  $A_i$ .

If  $A_i^* \neq A_i$ , the terminal ends the session; otherwise it computes  $RPW_i^* = h(PW_i^* || \delta_i^* || r)$ ,  $d_i^* = f_i \oplus h(ID_i || RPW_i^*)$ ,  $RPW_i^{new} = h(PW_i^{new} || \delta_i^* || r)$ ,  $A_i^* = h(h(ID_i^* || h(PW_i^{new} || \delta_i^*)) \bmod l_0, f_i^{new} = d_i^* \oplus h(ID_i^* || RPW_i^{new})$ , then replaces  $\{f_i, A_i\}$  with  $\{f_i^{new}, A_i^{new}\}$ .

#### 4.6 Re-registration Phase

According to our scheme, once the value of  $SUM$  exceeds the preset value, the user's account will be suspended. Therefore, it is necessary to provide a way for the users to activate their account. Usually, people's identities are personal-related value, it is not convenient to change the identity. Our scheme allow the user to re-register using the previous identity to active their account as follows:

Step 1. The  $U_i \rightarrow$  smart terminal:  $\{ID_i^*, PW_i^*, fng_i^*, PW_i^{new}, revoke - request\}$ . The user initiates the re-registration request to the smart terminal.

Step 2.  $U_i \rightarrow CS: \{ID_i^*, RPW_i', x_i, revoke - request\}$

The smart terminal will firstly verify the identity of the user: computes  $\delta_i^* = Rep(fng_i^*, \tau_i)$ ,  $A_i^* = h(ID_i^* || PW_i^* || \delta_i^*) \bmod l_0$ , compares  $A_i^*$  with  $A_i$ .

If  $A_i^* \neq A_i$ , rejects; Otherwise, selects a new random number  $r_i$ , computes  $RPW'_i = h(PW_i^{new} || \delta_i^* || r_i)$ .

Step 3.  $CS \Rightarrow U_i: \{f_i^{new}, x_i^{new}, P, Y\}$   
 The cloud center  $CS$  first checks the valid of  $ID_i$  and  $x_i$ : if any of them are not in the database,  $CS$  rejects the request; otherwise,  $CS$  picks the new unique random number  $x_i^{new}$ , computes  $d_i = h(ID_i^* || y || x_i^{new})$ ,  $f_i^{new} = h(RPW'_i || ID_i^*) \oplus d_i^{new}$ , and stores  $\{ID_i^*, x_i^{new}, SUM = 0\}$ .

Step 4. The smart terminal selects a random number  $r^{new}$ , computes:  $RPW_i = h(PW_i || \delta_i || r^{new})$ ,  $A_i^{new} = h(ID_i^* || PW_i^{new} || \delta_i^*) \bmod l_0$ ,  $f_i^{new} = h(ID_i^* || RPW_i) \oplus h(ID_i^* || RPW'_i) \oplus f'_i$ , keeps  $\{f_i^{new}, A_i^{new}, x_i^{new}, r, \tau_i, P, Y, l_0\}$ .

#### 4.7 Dynamics Node Addition Phase

When a new sensor node wants to join in the network, it can register to the gateway as the sensor node registration phase in Section. 4.1. After it successfully register, the gateway should inform the cloud center the identity ( $SID_j$ ) of the new sensor node as follows:

Step 1.  $GN_k \Rightarrow CS: \{SID_j, h(SID_j || X_{G_k})\}$ .

Step 2. The cloud center computes  $X'_{G_k} = h(GID_k || x)$ , then compares  $h(SID_j || X'_{G_k})$  with  $h(SID_j || X_{G_k})$ . If they are equal, the cloud center adds  $SID_j$  in the database, and gives a positive response to the gateway. Otherwise, the cloud center rejects the request.

### 5 Formal security analysis

In this section, the security of the proposed scheme are analyzed under the model defined in Section 3. When the simulation begins, the algorithm **Init** first runs an algorithm  $\mathcal{G}$  to generate a  $q$ -order subgroup  $P$  on an elliptic curve  $E/F_p$  over the finite field  $F_p$  (where  $p$  and  $q$  are two large primes, and  $|p| = \ell$  (security parameter)), several collision-resistant hash functions  $\mathcal{H}_i: \{0, 1\}^* \rightarrow \{0, 1\}^{l_i}$  ( $i = 0, 1, 2, 3$ ), the encryption and decryption function  $\mathcal{E}(\cdot)/\mathcal{D}(\cdot): \{0, 1\}^* \rightarrow \{0, 1\}^l$ , and two long-term private keys and a public key  $(x/y, yP)$ . In our proof, we let the adversary  $\mathcal{A}$  interact with honest participants through querying oracles and controlling the simulator. Eventually, with all information from the oracles,  $\mathcal{A}$  tries to determine whether a given number is a valid key to break the protocol. Furthermore, before the security analysis, we recall the following hypothesis:

**Computational Diffie-Hellman (CDH) problem:** let  $g$  be the generator of  $\mathcal{G}$ , given  $g^x$  and  $g^y$ , the advantage for  $\mathcal{A}$  to compute  $g^{xy}$  in polynomial time  $t$  is:  $Adv^{CDH}(t) \leq \varepsilon$ , where  $\varepsilon$  is an ignorable small number.

**Elliptic Curve Computational Diffie-Hellman (ECDH) problem:** given  $aP$  and  $bP$  in  $\mathcal{G}$ , the advantage for  $\mathcal{A}$  to compute  $abP$  within polynomial time  $t$  is:  $Adv^{ECDH}(t) \leq \varepsilon$ .

**Theorem 1.** Let  $\mathcal{P}$  be the protocol we proposed.  $|\mathcal{D}|$  be the space of password, and  $l$  be the security length. Then an adversary against the semantic security of  $\mathcal{P}$  makes  $q_s$  times  $Send(\cdot)$ -queries,  $q_e$  times  $Execute(\cdot)$ -queries and  $q_h$  times  $hash(\cdot)$ -queries with the polynomial time  $t$ , then her advantage to break the semantic security of  $\mathcal{P}$  is:

$$\begin{aligned} Adv_{\mathcal{P}}^{(ake)}(\mathcal{A}) \leq & \frac{(q_s + q_e)^2}{2p} + \frac{2q_h^2 + 2(q_s + q_e)^2 + (2q_s + q_h)^2 + 4q_s^2}{2^l} \\ & + C'q_{send}' + q_h(1 + 2(q_s + q_e)^2)(Adv_{\mathcal{P}}^{ECDH}(t') + Adv_{\mathcal{P}}^{CDH}(t')) \end{aligned}$$

where  $C'$  and  $s'$  are Zipf parameters [31],  $T_m$  is time for scalar multiplication operation in  $\mathcal{G}$ , and  $t' \leq t + (q_s + q_e + 1) \cdot T_m$ .

**Proof.** We prove **Theorem 1** via a sequence of games from a real attack game  $G_0$  to game  $G_6$ . The advantage between the adversary of these games is gradually decreasing to zero. The detailed proof can be found in Appendix A.



## 6 Performance Analysis

In this section, we compare our scheme with the state-of-the-art relevant schemes in terms of the security, computation cost, communication and storage cost, as shown in Table 4, Table 5 and Table 6 respectively. Computation cost refers to the calculation time required for each participant to complete the authentication. Communication cost refers to the bit size of the messages transmitted among participants. Storage cost refers to the bits size of parameters stored in each participants. We assume that the bit size of  $l_0$  is 32 bits, the random number, identity, timestamp are 128 bits, the hash output and ECC-based parameters are 160 bits, and the secret key of symmetric-cryptosystem-based and the extended-chaotic-maps-cryptosystem-based schemes are 1024 bits. We let  $T_C$ ,  $T_P$ ,  $T_B$ ,  $T_H$ ,  $T_S$  denote the operation time of chebysev chaotic-map, elliptic curve point multiplication, biometric fuzzy extracting, hash and symmetric encryption, respectively. Note that we ignore some lightweight operations such as XOR and  $\parallel$ . Based on [10], when using Intel(R) i3-530 2.93-GHz and the standard cryptographic library MIRACL, the running time for the modular exponentiation, the ECC point multiplication, symmetric cryptography (AES-128) and hash function (SHA-1) is  $1.169ms$ ,  $0.508ms$ ,  $0.541\mu s$  and  $0.693\mu s$ , respectively. Note that, we use this environment to approximate the use side, gateway and sensor nodes. Although, the running time of these operations on three participants are different, it does not affect the results of the comparisons and this approach has been accepted by the community, and some recent typical works include [3, 32, 35, 38]. Furthermore, based on [32], we can compute the running time of the big-exponent modular exponentiation  $T_{be} \approx 1.169 * 8 = 9.352ms$ , the small-exponent modular exponentiation  $T_{se} \approx 17/1024 * T_{be} = 0.156ms$  for RSA  $|n| = 1024$  and  $e = 2^{16} + 1$ . Based on [35, 38], we have  $T_C \approx T_P \approx 0.508ms$ .

As shown in Table 3, to test the feasibility and efficiency of the RSA initialization algorithm, we write the initiation algorithm using the Java language and conduct it on different environments. The result indicates that the running time of the RSA initialization on a smart phone released in 2016 which includes MSM8998 CPU, and 6GB LPDDR4 memory along with H2OS 1.4 system (based on Android 6.0), is approximately  $21ms$  when the length of the private key of RSA is 1024 bits. Furthermore, note that the addition of biometric factor will inevitably increase the computation costs on the user side, but it increases the difficulty for adversaries to attack authentication schemes.

From the security perspective as shown in Table 4, our scheme is the only one that satisfies all eleven widely-accepted criteria [6]. Among the remaining schemes, Wang et al. [32] and Li et al. [33] perform the best, they achieve ten criteria and cannot meet the indicator C6 “No password exposure”. The schemes of Sharif et al. [34], Wu et al. [36], Amin et al. [37] and Wazid et al. [38] only use symmetric cryptographic algorithms and all cannot achieve forward secrecy.

From the computation cost perspective as shown in Table 5, our scheme has the lowest computation cost on gateways ( $0.005ms$ ), and our computation cost ( $0.159ms$ ) on sensor nodes is even comparable to these schemes using only symmetric cryptographic algorithms (Sharif et al. [34]  $0.003ms$ , Wu et al. [36]  $0.003ms$ , Amin et al. [37]  $0.004ms$ , Wazid et al. [38]  $0.005ms$ ), and is much lower than these schemes that also use asymmetric cryptographic algorithms (Wang et al. [32]  $0.159ms$ , Li et al. [33]  $1.019ms$ , Srinivas et al. [40]  $1.020ms$ , Li et al. [3]  $1.019ms$ , Park et al. [39],  $1.019ms$ , Reddy et al. [26],  $1.019ms$ ). However, our computation cost on the user side is higher than most schemes. Yet, since the user usually owns a powerful smart terminal, such as smart phone, conducting these cryptographic algorithms is not a bottleneck. Besides, the computation cost on user side only affect the user experience. Specifically, to initiate an access request, in our scheme, the user needs to cost nearly  $1.02s$  when assuming that the time for biometric verification is  $1.00s$  [32], and this computation cost on the user side is acceptable. To

**Table 3** The running time of RSA initiation algorithm

| Experimental platform                                                                                         | RSA( $ n =1024$ ) | RSA( $ n =2048$ ) |
|---------------------------------------------------------------------------------------------------------------|-------------------|-------------------|
| a smart phone released in 2016 with MSM8998 CPU, 6GB LPDDR4 memory and H2OS 1.4 system (based on Android 6.0) | 21ms              | 103ms             |
| Common laptop with Intel(R) Xeon(R), CPU E5-2640 v4 @ 2.40GHz and 512G                                        | 13ms              | 84ms              |
| Common laptop with Intel(R) Xeon(R) Gold 6254, CPU @3.10GHz and 256G                                          | 11ms              | 69ms              |



Table 4 Security comparison among relevant authentication schemes

| Protocol        | Year | Ref. | Evaluation Criteria |    |    |    |    |    |    |    |    |     |     |
|-----------------|------|------|---------------------|----|----|----|----|----|----|----|----|-----|-----|
|                 |      |      | C1                  | C2 | C3 | C4 | C5 | C6 | C7 | C8 | C9 | C10 | C11 |
| Wang et al.     | 2019 | [32] | ✓                   | ✓  | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✓  | ✓   | ✓   |
| Li et al.       | 2019 | [33] | ✓                   | ✓  | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✓  | ✓   | ✓   |
| Sharif et al.   | 2019 | [34] | ✓                   | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✓  | ✗  | ✗   | ✗   |
| Srinivas et al. | 2018 | [35] | ✓                   | ✓  | ✓  | ✓  | ✗  | ✗  | ✓  | ✓  | ✗  | ✗   | ✓   |
| Li et al.       | 2018 | [3]  | ✓                   | ✓  | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✗  | ✗   | ✓   |
| Wu et al.       | 2018 | [36] | ✓                   | ✗  | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✗  | ✗   | ✗   |
| Amin et al.     | 2018 | [37] | ✓                   | ✓  | ✓  | ✓  | ✗  | ✗  | ✓  | ✓  | ✗  | ✗   | ✗   |
| Wazid et al.    | 2017 | [38] | ✓                   | ✓  | ✓  | ✓  | ✗  | ✗  | ✓  | ✓  | ✗  | ✗   | ✗   |
| Park et al.     | 2016 | [39] | ✓                   | ✓  | ✓  | ✓  | ✗  | ✗  | ✓  | ✗  | ✗  | ✗   | ✓   |
| Reddy et al.    | 2016 | [26] | ✓                   | ✗  | ✓  | ✓  | ✓  | ✗  | ✓  | ✓  | ✓  | ✗   | ✓   |
| Our scheme      | -    |      | ✓                   | ✓  | ✓  | ✓  | ✓  | ✓  | ✓  | ✓  | ✓  | ✓   | ✓   |

Table 5 Computation cost among relevant authentication schemes

| Protocol        | Year | Ref. | Login (ms)                             | Authentication (ms)         |                                 |                                 |
|-----------------|------|------|----------------------------------------|-----------------------------|---------------------------------|---------------------------------|
|                 |      |      | User                                   | User                        | Gateway                         | Sensor Node                     |
| Wang et al.     | 2019 | [32] | $T_{se}+8T_H+T_I \approx 21.162$       | $T_{be}+3T_H \approx 9.354$ | $T_{be}+T_S+6T_H \approx 9.356$ | $T_{se}+T_S+4T_H \approx 0.159$ |
| Li et al.       | 2019 | [33] | $2T_P+T_B+7T_H+T_S \approx T_B+1.021$  | $T_P+3T_H \approx 0.510$    | $T_P+8T_H \approx 0.513$        | $2T_P+4T_H \approx 1.018$       |
| Sharif et al.   | 2019 | [34] | $T_B+6T_H \approx T_B+0.004$           | $5T_H \approx 0.003$        | $17T_H \approx 0.012$           | $5T_H \approx 0.003$            |
| Srinivas et al. | 2018 | [35] | $T_C+T_B+11T_H \approx T_B+0.516$      | $T_C+3T_H \approx 0.510$    | $10T_H \approx 0.007$           | $2T_C+6T_H \approx 1.020$       |
| Li et al.       | 2018 | [3]  | $2T_P+T_B+5T_H \approx T_B+0.019$      | $T_P+2T_H \approx 0.509$    | $T_P+6T_H \approx 0.512$        | $2T_P+4T_H \approx 1.019$       |
| Wu et al.       | 2018 | [36] | $5T_H \approx 0.003$                   | $6T_H \approx 0.004$        | $15T_H \approx 0.010$           | $5T_H \approx 0.003$            |
| Amin et al.     | 2018 | [37] | $4T_H \approx 0.003$                   | $8T_H \approx 0.006$        | $15T_H \approx 0.010$           | $6T_H \approx 0.004$            |
| Wazid et al.    | 2017 | [38] | $T_B+4T_H \approx T_B+0.003$           | $5T_H+T_S \approx 0.004$    | $11T_H+2T_S \approx 0.009$      | $7T_H+T_S \approx 0.005$        |
| Park et al.     | 2016 | [39] | $T_P+T_B+6T_H \approx T_B+0.512$       | $T_P+4T_H \approx 0.511$    | $11T_H \approx 0.008$           | $2T_P+4T_H \approx 1.019$       |
| Reddy et al.    | 2016 | [26] | $2T_P+2T_H \approx 1.017$              | $T_P+10T_H \approx 0.511$   | $2T_P+7T_H \approx 1.021$       | $2T_P+5T_H \approx 1.019$       |
| Our scheme      | -    |      | $2T_P+T_B+7T_H+T_I \approx T_B+22.021$ | $T_{be}+3T_H \approx 9.354$ | $5T_H+2T_S \approx 0.005$       | $T_{se}+4T_H+T_S \approx 0.159$ |

finish the last step of the authentication phase, the user costs 9.354ms, and this increase in time is too short to be noticeable (and thus acceptable).

From the communication and storage cost perspective as shown in Table 6, the communication cost in registration phase of the schemes in the table is close, expect for Wang et al.’s scheme [32] where its gateway costs 2592 bits in registration phase. As for the communication cost in login and authentication phase, our cost on gateways is comparable to other schemes, and the cost on user sides and sensor nodes is slightly above average. The storage cost of our scheme is comparable to other schemes. Note that, Wang et al.’s scheme [32] and our scheme both exploit the imbalanced computational nature of the RSA cryptosystem to achieve forward secrecy with low computation cost on sensor nodes (0.159ms). However, the communication and storage cost of our scheme is obviously smaller than their scheme, the main reason of this is that we combine ECC-based cryptosystem with RSA-based cryptosystem. The 160-bit ECC-based cryptosystem provides the same security level as that for 1024-bit RSA-based cryptosystem, so our scheme cost less communication and storage workload.

In conclusion, compared with other schemes, the computation cost of our scheme on user side are higher than most comparison schemes, and our scheme requires that the user terminal can support RSA cryptographic algorithm and Elliptic Curve Cryptography algorithm, simultaneously. As we analyzed above, this small defect is acceptable when the smart phone is getting popular. Besides, our scheme’s communication cost on user side and sensor nodes is a little bit higher than some of schemes. However, our scheme meets all eleven security requirements under the most harsh adversary model; our computation cost on gateways is the smallest among all the comparison schemes; our computation cost on sensor nodes is comparable to those insecure schemes that use only symmetric cryptographic algorithms, and is superior to those that use asymmetric cryptographic algorithms. In brief, our scheme provides a good balance between performance and security, and is more suitable for the systems that have a mass of resource-constrained sensor nodes.

**Table 6** Communication and storage cost among relevant authentication schemes

| Protocol        | Year | Ref. | Communication cost I (bits) |         |         | Communication cost II (bits) |         |         | Storage cost (bits) |         |         |
|-----------------|------|------|-----------------------------|---------|---------|------------------------------|---------|---------|---------------------|---------|---------|
|                 |      |      | User                        | Gateway | Sensors | User                         | Gateway | Sensors | User                | Gateway | Sensors |
| Wang et al.     | 2019 | [32] | 288                         | 2560    | 128     | 3392                         | 2656    | 1344    | 2528                | 1408    | 288     |
| Li et al.       | 2019 | [33] | 416                         | 832     | 128     | 640                          | 928     | 480     | 800                 | 416     | 288     |
| Sharif et al.   | 2019 | [34] | 128                         | 320     | 448     | 1216                         | 1056    | 448     | 608                 | 1280    | 320     |
| Srinivas et al. | 2018 | [35] | 320                         | 320     | 128     | 928                          | 768     | 3448    | 736                 | 3328    | 288     |
| Li et al.       | 2018 | [3]  | 416                         | 640     | 128     | 640                          | 960     | 480     | 896                 | 1312    | 288     |
| Wu et al.       | 2018 | [36] | 288                         | 864     | 128     | 864                          | 1408    | 736     | 640                 | 1408    | 416     |
| Amin et al.     | 2018 | [37] | 288                         | 768     | 128     | 864                          | 1120    | 320     | 576                 | 1440    | 288     |
| Wazid et al.    | 2017 | [38] | 288                         | 448     | 128     | 576                          | 1184    | 608     | 864                 | 2432    | 288     |
| Park et al.     | 2016 | [39] | 288                         | 768     | 128     | 736                          | 1216    | 448     | 608                 | 576     | 288     |
| Reddy et al.    | 2016 | [26] | 160                         | 928     | 128     | 928                          | 1088    | 320     | 768                 | 320     | 288     |
| Our scheme      | -    |      | 288                         | 704     | 128     | 2688                         | 1812    | 1344    | 928                 | 1184    | 288     |

Communication cost I records the communication cost during the registration phase.

Communication cost II records the communication cost during the login and authentication phase.

## 7 Conclusion

To ensure the sensitive data stored in sensor nodes cannot be accessed by any unauthorized entity, numerous user authentication schemes for industry 4.0 were proposed. However, most of them cannot balance the conflicts between security and efficiency, and the major challenge is to achieve forward secrecy in a resource-constrained sensor nodes environment. In this paper, we exploit the RSA cryptosystem's computational imbalance at the encryption side and the decryption side, and make full use of the computation and storage capability of the cloud center to design a cloud-aided efficient user authentication scheme with forward secrecy for industry 4.0. We formally prove its security under the random oracle model, and compare it with state-of-the-art relevant schemes. The results show the superiority of our scheme.

**Acknowledgements** This research is supported by the National Key Research and Development Plan of China under Grant No.2018YFB0803605, and by the National Natural Science Foundation of China under Grant No.61802006.

## References

- 1 S. Kemmerer, Manufacturing interoperability program: A synopsis, National Institute of Standards and Technology, Tech. Rep., 2009.
- 2 Sahil G., Kuljeet K., Georges K. and Choo K.K.R., Towards Secure and Provable Authentication for Internet of Things: Realizing Industry 4.0. *IEEE Internet of Things Journal*, 2019, doi:10.1109/JIOT.2019.2942271.
- 3 Li X., Niu J., Bhuiyan M.Z.A., Wu F., Karupiah M., and Kumari S., A robust ecc-based provable secure authentication protocol with privacy preserving for industrial internet of things, *IEEE Trans. Ind. Inform.*, 2018, 14(8): 3599–3609.
- 4 Das A.K., Wazid M., Kumar N., Khan M.K., Choo K.K.R. and Park Y., Design of Secure and Lightweight Authentication Protocol for Wearable Devices Environment, *IEEE Journal of Biomedical & Health Informatics*, 2017, 22(14): 1310–1322.
- 5 Lin C., He D., Kumar N., Choo K.K.R., Vinel A. and Huang X., Security and privacy for the internet of drones: Challenges and solutions, *IEEE Communications Magazine*, 2018, 56(1): 64–69.
- 6 Wang D., Li W., and Wang P., Measuring two-factor authentication schemes for real-time data access in industrial wireless sensor networks, *IEEE Trans. Ind. Inform.*, 2018, 14(9): 4081–4092.
- 7 Kumari S., Karupiah M., Das A.K., Li X., Wu F. and Kumar N., A secure authentication scheme based on elliptic curve cryptography for IoT and cloud servers, *Journal of Supercomputing*, 2017, 74(12): 6428–6453.
- 8 Wang C., Wang D., Tu Y., Xu G., Wang H., Evaluating the node capture attack in user authentication scheme of wireless sensor networks, *IEEE Trans. Depend. Secur. Comput.*, 2020, Doi:10.1109/TDSC.2020.2974220
- 9 Bresson E., Chevassut O., and Pointcheval D., Security proofs for an efficient password-based key exchange, In *Proceedings of ACM CCS*, 2003: 41–50.
- 10 Wang D. and Wang P., Two birds with one stone: Two-factor authentication with security beyond conventional bound, *IEEE Trans. Depend. Secur. Comput.*, 2018, 15(4): 708–722.
- 11 He D., Zeadally S., Kumar N., and Wei W., Efficient and anonymous mobile user authentication protocol using self-certified public key cryptography for multi-server architectures, *IEEE Trans. Inform. Foren. Secur.*, 2016, 11(9): 2052–2064.
- 12 Meng W., Li W., Jiang L., and Zhou J., Socialauth: Designing touch behavioral smartphone user authentication based on social networking applications, In *Proceedings of IFIP SEC*, 2019, 562: 180–193.
- 13 Meng W., Wang Y., Wong D.S., Wen S., and Xiang Y., Touchwb: Touch behavioral user authentication based on web browsing on smartphones, *J Netw. Comput. Appl.*, 2018, 117: 1–9.

14 Wu T.D., The secure remote password protocol. In Proceedings of NDSS, 1998, 98: 97–111.

15 The heartbleed bug. [Online]. Available: <http://heartbleed.com/>

16 E. Rescorla, The transport layer security (tls) protocol version 1.3, 2018. [Online]. Available:[https://datatracker.ietf.org/doc/rfc8446/?include\\_text=1](https://datatracker.ietf.org/doc/rfc8446/?include_text=1)

17 J. Kastrnakes. Wi-fi security is starting to get its biggest upgrade in over a decade. 2018, [Online]. Available: <https://www.theverge.com/circuitbreaker/2018/6/26/17501594/wpa3-wifi-security-certification>

18 Das M.L., Two-factor user authentication in wireless sensor networks, IEEE Trans. Wirel. Commun., 2009, 8(3): 1086–1090.

19 Fan R., He D., Pan X., and Ping L., An efficient and dos-resistant user authentication scheme for two-tiered wireless sensor networks, J. Zhejinag Univ. Sci. C, 2011, 12(7): 550–560.

20 Wang D. and Wang P., On the anonymity of two-factor authentication schemes for wireless sensor networks: Attacks, principle and solutions, Comput. Netw., 2014, 73(C): 41–57.

21 Das A., Sharma S., Chatterjee P., and Sing J., A dynamic password-based user authentication scheme for hierarchical wireless sensor networks. J. Netw. Comput. Appl., 2012, 35(5): 1646–1656.

22 Xue K., Ma C., Hong P., and Ding R., A temporal-credential-based mutual authentication and key agreement scheme for wireless sensor networks, J Netw. Comput. Appl., 2013, 36(1): 316–323.

23 Ma C., Wang D., and Zhao S., Security flaws in two improved remote user authentication schemes using smart cards, Int. J. Commun. Syst., 2012, 27(10): 2215–2227.

24 Choi Y., Lee D., Kim J., Jung J., Nam J., and Won D., Security enhanced user authentication protocol for wireless sensor networks using elliptic curves cryptography, Sensors, 2014, 14(6): 10081–10106.

25 He D., Kumar N., and Chilamkurti N., A secure temporal-credential-based mutual authentication and key agreement scheme with pseudo identity for wireless sensor networks, Inform. Sci., 2015, 321: 263–277.

26 Reddy A.G., Das A.K., Yoon E.J., and Yoo K.Y., A secure anonymous authentication protocol for mobile services on elliptic curve cryptography, IEEE Access, 2016, 4: 4394–4407.

27 Jiang Q., Zeadally S., Ma J., and He D., Lightweight three-factor authentication and key agreement protocol for internet-integrated wireless sensor networks, IEEE Access, 2017, 5: 3376–3392.

28 Wang D., He D., Wang P., and Chu C., Anonymous two-factor authentication in distributed systems: Certain goals are beyond attainment, IEEE Trans. Depend. Secur. Comput., 2015, 12(4): 428–442.

29 Wang D. and Wang P., On the implications of zipf’s law in passwords, In: Proceedings of ESORICS 2016: 111–131.

30 Li W., Wang D., and Wang P., Insider attacks against multi-factor authentication protocols for wireless sensor networks, Ruan Jian Xue Bao/Journal of Software (in Chinese), 2019, 30(8): 2375–2391.

31 Wang D., H. Cheng, P. Wang, X. Huang, and G. Jian, Zipf’s law in passwords, IEEE Trans. Inform. Foren. Secur., 2017, vol.12, no.11, pp. 2776–2791.

32 Wang D., Wang P., and Wang C., Efficient multi-factor user authentication protocol with forward secrecy for real-time data access in wsns, ACM Trans. Cyber-Physical System, 2019, Doi:10.1145/acm.tcps.3325130.

33 Li X., Peng J., Obaidat M.S., Wu F., Khan M.K., and Chen C., A secure three-factor user authentication protocol with forward secrecy for wireless medical sensor network systems, IEEE Sys. J., 2019, Doi:10.1109/JSYST.2019.2899580.

34 Ostad-Sharif A., Arshad H., Nikooghadam M., and Abbasinezhad-Mood D., Three party secure data transmission in iot networks through design of a lightweight authenticated key agreement scheme, Future Gener. Comput. Sys., 2019, 100: 882–892.

35 Srinivas J., Das A.K., Wazid M., and Kumar N., Anonymous lightweight chaotic map-based authenticated key agreement protocol for industrial internet of things, IEEE Trans. Depend. Secur. Comput., 2018, Doi: 10.1109/TDSC.2018.2857811.

36 Wu F., Li X., Sangaiah A.K., Xu L., Kumari S., Wu L., Shen J., A lightweight and robust two-factor authentication scheme for personalized healthcare systems using wireless medical sensor networks, Future Gener. Comput. Sys., 2018, 82: 727–737.

37 Amin R., Islam S.H., Biswas G., Khan M.K., and Kumar N., A robust and anonymous patient monitoring system using wireless medical sensor networks, Future Gener. Comput. Sys., 2018, 80: 483–495.

38 Wazid M., Das A.K., Odelu V., Kumar N., and Susilo W., Secure remote user authenticated key establishment protocol for smart home environment, IEEE Trans. Depend. Secur. Comput., 2017, Doi:10.1109/TDSC.2017.2764083.

39 Park Y. and Park Y., Three-factor user authentication and key agreement using elliptic curve cryptosystem in wireless sensor networks, Sensors, 2016, 16(12): 2123–2140.

40 Srinivas J., Mukhopadhyay S., and Mishra D., Secure and efficient user authentication scheme for multi-gateway wireless sensor networks,” Ad Hoc Netw., 2017, 54(C): 147–169.

41 Dolev D., Yao A., On the security of public key protocols. IEEE Trans. Inform. Theory, 1983, 29(2): 198–208.

Appendix A FORMAL SECURITY ANALYSIS OF OUR SCHEME

In the proof below, we prove **Theorem 1** via a sequence of games starting at a real attack game  $G_0$  and ending up with  $G_6$  where the advantage of adversary to attack the protocol is zero.

**Game  $G_0$ :** It is a real attack, thus we have

$$Adv_P^{ake}(A) = 2Pr[ Succ_0 ] - 1 \tag{A1}$$

where  $Succ_n$  is the event that  $A$  in Game  $G_n$  correctly guesses  $b$  in  $Test(\cdot)$ -query.

**Game  $G_1$ :** This game simulates several hash functions,  $\mathcal{H}_i : \{0, 1\}^* \rightarrow \{0, 1\}^l$  ( $i = 1, 2$ ), and  $\mathcal{H}'_i$ . Furthermore, all the queries are simulated as the real protocol, three lists need to be maintained:  $\Lambda_{\mathcal{H}}$  which records the replies to hash queries;  $\Lambda_{\mathcal{M}}$  which stores the transcripts in those games;  $\Lambda_{\mathcal{A}}$  which stores hash-queries asked by the adversary  $\mathcal{A}$ ;  $\Lambda_{\varepsilon}$  which stores encryption-queries asked by the adversary  $\mathcal{A}$ ;  $\Lambda_{\mathcal{D}}$  which stores decryption-queries asked by the adversary  $\mathcal{A}$ . Then we have

$$|Pr[Succ_1] - Pr[Succ_0]| = 0 \quad (A2)$$

**Game  $G_2$ :** In this game, we removes collisions:

- The probability of collisions caused by hash function is  $\frac{q_h^2}{2^{l+1}}$ .
- The probability for collisions of  $k_x$ ,  $k_g$  and  $k_j$  are  $\frac{(q_s+q_e)^2}{2^{l+1}}$ .
- The probability for collisions of  $k_i$  is at most  $\frac{(q_s+q_e)^2}{2^p}$ .

Thus, we have:

$$|Pr[Succ_2] - Pr[Succ_1]| \leq \frac{(q_s + q_e)^2}{2^p} + \frac{q_h^2 + (q_s + q_e)^2}{2^{l+1}} \quad (A3)$$

**Game  $G_3$ :** This game considers such an attack where  $\mathcal{A}$  luckily guesses messages correctly without querying hash oracle:

- For  $MSG_1$ , the simulator checks whether  $(ID_i || SID_j || *, *)$ ,  $(* || ID_i || * || * || SID_j || *, M_2)$ ,  $(ID_i || *, *) \in \Lambda_{\mathcal{A}}$ , and the probability of these items in  $\Lambda_{\mathcal{A}}$  is  $\frac{(q_s+2q_h)^2}{2^l}$ .
- For  $MSG_2$ , the simulator checks whether  $(* || * || GID_k || SID_j || *, M_4) \in \Lambda_{\mathcal{A}}$ , the probability is  $\frac{q_s^2}{2^l}$ .
- For  $MSG_3$ , the simulator checks whether  $(* || * || * || SID_j || GID_k || *, M_6) \in \Lambda_{\mathcal{A}}$ , the probability is  $\frac{q_s^2}{2^l}$ .
- For  $MSG_4$ , the simulator checks whether  $(* || * || * || SID_j || *, (* || SID_j || GID_k || * || * || M_7, M_8)$  and  $(* || * || M_7, M_9) \in \Lambda_{\mathcal{A}}$ , and the probability is  $\frac{(2q_s+q_h)^2}{2^l}$ .
- For  $MSG_5$ , the simulator checks whether  $(* || * || GID_k || SID_j || * || M_7 || M_9, M_{10}) \in \Lambda_{\mathcal{A}}$ , and the probability is  $\frac{q_s^2}{2^l}$ .
- For  $MSG_6$ , the simulator checks whether  $(* || * || * || ID_i || SID_j || * || * || M_7 || M_9, M_{11}) \in \Lambda_{\mathcal{A}}$ , the probability is  $\frac{q_s^2}{2^l}$ .

Thus, we have:

$$|Pr[Succ_4] - Pr[Succ_3]| \leq \frac{(q_s + 2q_h)^2 + (2q_s + q_h)^2 + 4q_s^2}{2^l} \quad (A4)$$

**Game  $G_4$ :** In this game,  $\mathcal{A}$  computes  $d_i$  correctly. Game  $G_4$  and  $G_3$  are indistinguishable unless the event where  $\mathcal{A}$  computes  $d_i$  via hash oracle with  $(ID_i || RPW_i)$  or  $(ID_i || y || x_i)$  happens, and we denote such an event as  $AskPara$ , then:

$$|Pr[Succ_4] - Pr[Succ_3]| \leq Pr[AskPara_4] \quad (A5)$$

$\mathcal{A}$  only has two ways to compute  $b_i$ : asking  $Corrupt(u, a)$ . It should note that  $\mathcal{A}$  can only ask one kinds of  $Corrupt(u, a)$  query, and we denote the possibility of  $\mathcal{A}$  computing  $b_i$  by using  $Corrupt(u, a)$  successfully as  $Pr[AskPara_4 \text{ with } Corr_a]$ , where  $a = 1, 2, 3$ . Then we have:

$$\begin{aligned} |Pr[AskPara_5 \text{ with } Corr_1]| &\leq \frac{q_s}{2^l} \\ |Pr[AskPara_5 \text{ with } Corr_2]| &\leq \frac{q_s}{2^l} + q_s \cdot P_{false} \\ |Pr[AskPara_5 \text{ with } Corr_3]| &\leq C' q_{send}^{s'} \end{aligned}$$

where  $P_{false}$  is the probability of two person who have similar  $fn_g$ .  $C'$  and  $s'$  are Zipf parameters [31].

According to the above equations, we have

$$|Pr[AskPara_4]| \leq \max\{|Pr[AskPara_4 \text{ with } Corr_a]|\} = C' q_{send}^{s'} \quad (A6)$$

**Game  $G_5$ :** This game applies the Elliptic Curve Gap Diffie-Hellman problem, and makes  $M_1$  and  $SK$  are independent for  $d_i$  and  $k_i$ . In this game, the adversary tries to compute the correct  $k_j$  and  $K_2$  with the history transcript, i.e. using the information from  $Execute(\cdot)$  queries.

$$|Pr[Succ_5] - Pr[Succ_4]| \leq q_h (Adv_p^{ECDH}(t') + Adv_p^{CDH}(t')) \quad (A7)$$

where  $t' \leq t + (q_s + q_e + 1) \cdot T_m$

**Game  $G_6$ :** This game considers forward secrecy. Thus  $\mathcal{A}$  can query  $Corrupt(S)$  or  $Corrupt(G)$ . After having asked one of these two queries  $\mathcal{A}$  can only ask  $Execute(\cdot)$ -query. Thus:

$$|Pr[Succ_6] - Pr[Succ_5]| \leq 2q_h(q_s + q_e) \cdot (Adv_{\mathcal{A}}^{ECDH}(t') + Adv_p^{CDH}(t')) \quad (A8)$$

Till now, there is no advantage for  $\mathcal{A}$  to guess the session key.